

4. Mapeamento da cadeia de valor e 3rd party

A InterMed depende fortemente de terceiros para operar uma parte significativa da sua cadeia de valor digital. Fornecedores de software clínico, operadores de telecomunicações, cloud providers, empresas de manutenção de equipamentos médicos conectados, prestadores de faturação eletrónica, suporte de microinformática e integradores de aplicações suportam processos essenciais à prestação de cuidados, à operação administrativa e à relação com doentes e parceiros. Apesar desta dependência, a organização não tem ainda uma visão consolidada de terceiros críticos nem das respetivas ligações a processos, sistemas e riscos de negócio.

A nova administração quer reduzir pontos cegos e pediu uma primeira leitura estruturada sobre dependências críticas. O objetivo não é ainda avaliar em detalhe todos os fornecedores, mas identificar onde a falha de um terceiro pode interromper atividade clínica, degradar serviços ao doente, afetar receita, gerar incumprimento regulatório ou criar exposição reputacional. **Este trabalho é particularmente importante porque a NIS2 dá grande relevância à segurança da cadeia de fornecimento, ao diretório de fornecedores, aos requisitos contratuais e ao risco de dependências críticas.**

A análise é dificultada por vários fatores: muitos contratos foram celebrados por áreas diferentes; algumas dependências estão “escondidas” em subcontratação ou cloud; não existe taxonomia única de criticidade; e o risco corporativo não reflete de forma consistente o impacto de falhas de terceiros. O exercício deve, por isso, mapear não só fornecedores “visíveis”, mas também interdependências entre serviços, infraestrutura, dados, suporte e continuidade.

Além disso, surgiram recentemente sinais de vulnerabilidade que tornam o caso mais realista. Em dois incidentes recentes, uma atualização mal gerida de um fornecedor causou indisponibilidade local de postos de trabalho e atrasos operacionais, e uma falha de conectividade externa afetou durante várias horas o acesso a aplicações centrais em duas unidades. Nenhum destes eventos foi formalmente traduzido em revisão de criticidade de fornecedores, o que mostra ausência de aprendizagem estruturada e insuficiente integração entre operação, risco e supply chain security.

Dados adicionais para análise

Considere estes dados:

- O fornecedor do DCE aloja parte da solução no seu próprio datacenter.

- O portal e a app dependem de cloud pública e APIs de terceiros.
- Os equipamentos de imagiologia e laboratório têm contratos de manutenção remota.
- O suporte de microinformática é prestado por um parceiro externo sem forte integração de reporting.
- O operador telecom suporta interligação entre unidades e acesso a serviços centrais.
- A faturação depende de integrações com seguradoras e entidades pagadoras.
- Não existe repositório único de contratos críticos.
- Não existe dono claro para o processo de third-party risk management. [cite:1][cite:2]

Questões

1. Quais são os terceiros críticos da InterMed e porquê?
2. Como classificaria a criticidade dos terceiros?
3. Que riscos de negócio e de cibersegurança decorrem dessas dependências?

Checklist de análise

- O fornecedor suporta processo essencial ou serviço clínico?
- A falha do fornecedor interrompe ou degrada atividade crítica?
- Há acesso do fornecedor a dados de saúde ou sistemas críticos?
- Existe subcontratação relevante?
- Há dependência tecnológica ou lock-in?
- Existe alternativa ou plano de saída?
- O contrato inclui segurança, continuidade e incident notification?
- A dependência está refletida no risco corporativo?
- O fornecedor já causou incidentes ou degradações?
- O fornecedor é monitorizado de forma proporcional à criticidade?

Folha de resposta

Fornecedor	Serviço/SI suportado	Processo afetado	Criticidade	Risco principal